Attribute verification, or lack of it, plays a particularly important role in the confidence we place in authorization decisions. No matter how good your authentication system or authorization policies are, if attributes can be spoofed, then you are at risk. When attributes are critical, they should be carefully proofed whenever they change to ensure they are correct. Authorization systems should dynamically evaluate attributes wherever possible, making sure their record of attributes is up-to-date with the source of truth. Long-lived credentials can be a source of out-of-date attributes that lead to unauthorized access.

Finally, auditing and logging can provide evidence that the identity system is working as designed. Logs should be systematically checked and used to create reports and feedback that management, data protection officers, security engineers, and developers can use to determine their level of confidence in the system.

2.6.4 The limits of technical confidence

Not every risk can be mitigated using technology. For example, even a perfect identity system can’t protect your organization against an employee with malicious intent, employee incompetence, or other types of insider threats. Some employees must have access to vulnerable systems to do their jobs, and you trust them to act according to policy and industry norms.

Policies are another place where the limits of technically based confidence can be found. Policy is a result of people defining rules according to some explicit or implicit governing process. The accounts, authentication, and authorization systems can all be doing their jobs, but that doesn’t mean that the policies you have in place are sufficient to protect the business or ensure your customers are secure from hackers, each other, or your employees. Do policies properly reflect the will of management? Do they properly reflect regulatory requirements? No technical solution can answer those and similar questions.

When we hit the limits of technology to provide confidence, we are left to mitigate the risk we face with either social norms or formal governance. Social norms often play a role in whether a system is perceived as fair or trustworthy. For example, in ride-sharing platforms like Uber or Lyft,